COMPLIANCE SENTINEL · AUDIT REPORT

Regulatory audit of demo-target-app

Run 1 · 2026-10-10 · triggered by manual

> 6 critical violations found. Action is needed.

Target repository	demo-target-app
Audited snapshot	content-dce38f2929e75c3947d078e5fd29e117b52a7560
Rules in scope	2
Obligations assessed	12
Findings	12
Analyst	offline-keyword-baseline
Model cost	$0.0000

Executive summary

This run audited **demo-target-app** against 2 new or amended rules. It assessed 12 obligations, which consolidated into 12 findings: 9 violations, 0 needing human review and 3 compliant.

VIOLATIONS BY SEVERITY	COUNT
CRITICAL	6
HIGH	3
MEDIUM	0
LOW	0

#	STATUS	OBLIGATION	RULE	PRIMARY LOCATION
1	CRITICAL	Personal data must not be exposed in application logs; logging must be limited to what is necessary and protected against unauthorised access.	Standards for Safeguarding Customer Information (FTC Safeguards Rule,...	`src/routes/patients.js:12`
2	CRITICAL	Credentials and secrets must not be stored in plaintext in source code, and passwords must be hashed before storage.	Standards for Safeguarding Customer Information (FTC Safeguards Rule,...	`src/config.js:7`
3	CRITICAL	Security incidents affecting personal data must trigger notification of the regulator within the mandated deadline; the incident workflow must include a notification step.	Standards for Safeguarding Customer Information (FTC Safeguards Rule,...	`src/routes/incidents.js:15`
4	CRITICAL	Personal data must not be exposed in application logs; logging must be limited to what is necessary and protected against unauthorised access.	Regulation (EU) 2016/679 (General Data Protection Regulation) - abrid...	`src/routes/patients.js:12`
5	CRITICAL	Credentials and secrets must not be stored in plaintext in source code, and passwords must be hashed before storage.	Regulation (EU) 2016/679 (General Data Protection Regulation) - abrid...	`src/config.js:7`
6	CRITICAL	Security incidents affecting personal data must trigger notification of the regulator within	Regulation (EU) 2016/679 (General	`src/routes/incidents.js:15`

		the mandated deadline; the incident workflow must include a notification step.	Data Protection Regulation) - abrid…	
7	HIGH	Personal data must be deleted or anonymised once it is no longer needed; a retention schedule must be enforced by an automated disposal process.	Standards for Safeguarding Customer Information (FTC Safeguards Rule,…	`src/jobs/index.js:6`
8	HIGH	Personal data must be deleted or anonymised once it is no longer needed; a retention schedule must be enforced by an automated disposal process.	Regulation (EU) 2016/679 (General Data Protection Regulation) - abrid…	`src/jobs/index.js:6`
9	HIGH	Where processing relies on consent, the system must capture an explicit opt-in and keep a record that demonstrates it; consent must not be assumed by default.	Regulation (EU) 2016/679 (General Data Protection Regulation) - abrid…	`schema.sql:10`
10	COMPLIANT	Personal data must be encrypted in transit over external networks.	Standards for Safeguarding Customer Information (FTC Safeguards Rule,…	`src/lib/db.js:9`
11	COMPLIANT	Access to personal data must be restricted to authenticated, authorised users under least privilege.	Standards for Safeguarding Customer Information (FTC Safeguards Rule,…	`src/middleware/auth.js:12`
12	COMPLIANT	Personal data must be encrypted in transit over external networks.	Regulation (EU) 2016/679 (General Data Protection Regulation) - abrid…	`src/lib/db.js:9`

Critical violations (6)

CRITICAL

Finding 1

Personal data must not be exposed in application logs; logging must be limited to what is necessary and protected against unauthorised access.

Code matching a known anti-pattern for "pii-logging" was found at the cited lines, which conflicts with the obligation.

REGULATION

Standards for Safeguarding Customer Information (FTC Safeguards Rule, 16 CFR Part 314) - abridged demo excerpt

Effective 2024-05-13 · https://www.ecfr.gov/current/title-16/chapter-I/subchapter-C/part-314

> **§ 314.4** (chunk 1)
> Abridged excerpt of 16 CFR Part 314 prepared for demonstration. Consult the official text in the Code of Federal Regulations before relying on it. § 314.4 Elements In order to develop, implement, and maintain your information security program, you shall: (c) Design and implement safeguards to control the risks you identify through risk assessment, including by: (1) Implementing and periodically reviewing access controls, including technical and, as appropriate, physical controls to authenticate and permit access only to authorized users to protect against the unauthorized acquisition of customer information, and to limit authorized users' access only to customer information that they need to perform their duties and functions; (3) Protect by encryption all customer information held or transmitted by you both in transit over external networks and at rest; (6)(i) Develop, implement, and m...

CODE EVIDENCE

src/routes/patients.js:12

```
  console.log(`Fetched patient ${patient.id}: ${patient.full_name}, SSN ${patient.ssn},
diagnosis ${patient.diagnosis}`);
```

src/routes/signup.js:10

```
  console.log("New signup", { email, fullName, dateOfBirth, ssn, phone });
```

CRITICAL

Finding 2

Credentials and secrets must not be stored in plaintext in source code, and passwords must be hashed before storage.

Code matching a known anti-pattern for "secrets-management" was found at the cited lines, which conflicts with the obligation.

REGULATION

Standards for Safeguarding Customer Information (FTC Safeguards Rule, 16 CFR Part 314) - abridged demo excerpt
Effective 2024-05-13 · https://www.ecfr.gov/current/title-16/chapter-I/subchapter-C/part-314

> **§ 314.4** (chunk 1)
> Abridged excerpt of 16 CFR Part 314 prepared for demonstration. Consult the official text in the Code of Federal Regulations before relying on it. § 314.4 Elements In order to develop, implement, and maintain your information security program, you shall: (c) Design and implement safeguards to control the risks you identify through risk assessment, including by: (1) Implementing and periodically reviewing access controls, including technical and, as appropriate, physical controls to authenticate and permit access only to authorized users to protect against the unauthorized acquisition of customer information, and to limit authorized users' access only to customer information that they need to perform their duties and functions; (3) Protect by encryption all customer information held or transmitted by you both in transit over external networks and at rest; (6)(i) Develop, implement, and m...

CODE EVIDENCE

src/config.js:7

```
    password: "Winter2024!portal",
```

src/config.js:10

```
  jwtSecret: "acme-portal-jwt-signing-secret",
```

src/config.js:12

```
    apiKey: "mailer-live-key-9f2c41d07a",
```

CRITICAL

Finding 3

Security incidents affecting personal data must trigger notification of the regulator within the mandated deadline; the incident workflow must include a notification step.

Code matching a known anti-pattern for "breach-notification" was found at the cited lines, which conflicts with the obligation.

REGULATION

Standards for Safeguarding Customer Information (FTC Safeguards Rule, 16 CFR Part 314) - abridged demo excerpt
Effective 2024-05-13 · https://www.ecfr.gov/current/title-16/chapter-I/subchapter-C/part-314

> **§ 314.4(j)** (chunk 2)
> § 314.4(j) Notification events (j) Notify the Federal Trade Commission about notification events. Upon discovery of a notification event involving the information of at least 500 consumers, you must notify the Federal Trade Commission as soon as possible, and no later than 30 days after discovery of the event.

CODE EVIDENCE

src/routes/incidents.js:15

```
  // TODO: tell someone about this
```

CRITICAL

Finding 4

Personal data must not be exposed in application logs; logging must be limited to what is necessary and protected against unauthorised access.

Code matching a known anti-pattern for "pii-logging" was found at the cited lines, which conflicts with the obligation.

REGULATION

Regulation (EU) 2016/679 (General Data Protection Regulation) - abridged demo excerpt
Effective 2018-05-25 · https://eur-lex.europa.eu/eli/reg/2016/679/oj

> **Article 5** (chunk 3)
> Abridged excerpt of Regulation (EU) 2016/679 prepared for demonstration. Consult the official text on EUR-Lex before relying on it. Article 5 Principles relating to processing of personal data 1. Personal data shall be: (c) adequate, relevant and limited to what is necessary in relation to the purposes for which they are processed ('data minimisation'); (e) kept in a form which permits identification of data subjects for no longer than is necessary for the purposes for which the personal data are processed ('storage limitation'); (f) processed in a manner that ensures appropriate security of the personal data, including protection against unauthorised or unlawful processing and against accidental loss, destruction or damage, using appropriate technical or organisational measures ('integrity and confidentiality'). 2. The controller shall be responsible for, and be able to demonstrate com...

CODE EVIDENCE

src/routes/patients.js:12

```
  console.log(`Fetched patient ${patient.id}: ${patient.full_name}, SSN ${patient.ssn},
diagnosis ${patient.diagnosis}`);
```

src/routes/signup.js:10

```
  console.log("New signup", { email, fullName, dateOfBirth, ssn, phone });
```

CRITICAL

Finding 5

Credentials and secrets must not be stored in plaintext in source code, and passwords must be hashed before storage.

Code matching a known anti-pattern for "secrets-management" was found at the cited lines, which conflicts with the obligation.

REGULATION

Regulation (EU) 2016/679 (General Data Protection Regulation) - abridged demo excerpt
Effective 2018-05-25 · https://eur-lex.europa.eu/eli/reg/2016/679/oj

> **Article 32** (chunk 5)
> Article 32 Security of processing 1. Taking into account the state of the art, the costs of implementation and the nature, scope, context and purposes of processing as well as the risk for the rights and freedoms of natural persons, the controller and the processor shall implement appropriate technical and organisational measures to ensure a level of security appropriate to the risk, including inter alia as appropriate: (a) the pseudonymisation and encryption of personal data; (b) the ability to ensure the ongoing confidentiality, integrity, availability and resilience of processing systems and services.

CODE EVIDENCE

src/config.js:7

```
    password: "Winter2024!portal",
```

src/config.js:10

```
  jwtSecret: "acme-portal-jwt-signing-secret",
```

src/config.js:12

```
    apiKey: "mailer-live-key-9f2c41d07a",
```

CRITICAL

Finding 6

Security incidents affecting personal data must trigger notification of the regulator within the mandated deadline; the incident workflow must include a notification step.

Code matching a known anti-pattern for "breach-notification" was found at the cited lines, which conflicts with the obligation.

REGULATION

Regulation (EU) 2016/679 (General Data Protection Regulation) - abridged demo excerpt
Effective 2018-05-25 · https://eur-lex.europa.eu/eli/reg/2016/679/oj

> **Article 33** (chunk 6)
> Article 33 Notification of a personal data breach to the supervisory authority 1. In the case of a personal data breach, the controller shall without undue delay and, where feasible, not later than 72 hours after having become aware of it, notify the personal data breach to the supervisory authority competent in accordance with Article 55, unless the personal data breach is unlikely to result in a risk to the rights and freedoms of natural persons. 5. The controller shall document any personal data breaches, comprising the facts relating to the personal data breach, its effects and the remedial action taken.

CODE EVIDENCE

src/routes/incidents.js:15

```
  // TODO: tell someone about this
```

High severity violations (3)

HIGH

Finding 7

Personal data must be deleted or anonymised once it is no longer needed; a retention schedule must be enforced by an automated disposal process.

No implementation of the "data-retention" control was found anywhere in the repository. The cited location is where it would normally be wired in.

REGULATION

Standards for Safeguarding Customer Information (FTC Safeguards Rule, 16 CFR Part 314) - abridged demo excerpt
Effective 2024-05-13 · https://www.ecfr.gov/current/title-16/chapter-I/subchapter-C/part-314

> **§ 314.4** (chunk 1)
> Abridged excerpt of 16 CFR Part 314 prepared for demonstration. Consult the official text in the Code of Federal Regulations before relying on it. § 314.4 Elements In order to develop, implement, and maintain your information security program, you shall: (c) Design and implement safeguards to control the risks you identify through risk assessment, including by: (1) Implementing and periodically reviewing access controls, including technical and, as appropriate, physical controls to authenticate and permit access only to authorized users to protect against the unauthorized acquisition of customer information, and to limit authorized users' access only to customer information that they need to perform their duties and functions; (3) Protect by encryption all customer information held or transmitted by you both in transit over external networks and at rest; (6)(i) Develop, implement, and m...

CODE EVIDENCE

src/jobs/index.js:6

```
function registerJobs() {
```

HIGH

Finding 8

Personal data must be deleted or anonymised once it is no longer needed; a retention schedule must be enforced by an automated disposal process.

No implementation of the "data-retention" control was found anywhere in the repository. The cited location is where it would normally be wired in.

REGULATION

Regulation (EU) 2016/679 (General Data Protection Regulation) - abridged demo excerpt
Effective 2018-05-25 · https://eur-lex.europa.eu/eli/reg/2016/679/oj

> **Article 5** (chunk 3)
> Abridged excerpt of Regulation (EU) 2016/679 prepared for demonstration. Consult the official text on EUR-Lex before relying on it. Article 5 Principles relating to processing of personal data 1. Personal data shall be: (c) adequate, relevant and limited to what is necessary in relation to the purposes for which they are processed ('data minimisation'); (e) kept in a form which permits identification of data subjects for no longer than is necessary for the purposes for which the personal data are processed ('storage limitation'); (f) processed in a manner that ensures appropriate security of the personal data, including protection against unauthorised or unlawful processing and against accidental loss, destruction or damage, using appropriate technical or organisational measures ('integrity and confidentiality'). 2. The controller shall be responsible for, and be able to demonstrate com…

CODE EVIDENCE

src/jobs/index.js:6

```
function registerJobs() {
```

HIGH

Finding 9

Where processing relies on consent, the system must capture an explicit opt-in and keep a record that demonstrates it; consent must not be assumed by default.

Code matching a known anti-pattern for "consent-capture" was found at the cited lines, which conflicts with the obligation.

REGULATION

Regulation (EU) 2016/679 (General Data Protection Regulation) - abridged demo excerpt
Effective 2018-05-25 · https://eur-lex.europa.eu/eli/reg/2016/679/oj

> **Article 7** (chunk 4)
> Article 7 Conditions for consent 1. Where processing is based on consent, the controller shall be able to demonstrate that the data subject has consented to processing of his or her personal data. 3. The data subject shall have the right to withdraw his or her consent at any time. It shall be as easy to withdraw as to give consent.

CODE EVIDENCE

schema.sql:10

```
  marketing_emails boolean NOT NULL DEFAULT true,
```

src/routes/signup.js:14

```
    VALUES ($1, $2, $3, $4, $5, $6, true)
```

src/routes/signup.js:22

```
    body: "Thanks for joining. You are now subscribed to our partner offers newsletter.",
```

Compliant (3)

Supporting code was found for these obligations.

COMPLIANT

Finding 10

Personal data must be encrypted in transit over external networks.

The cited lines implement the "encryption-in-transit" control and no conflicting code was found.

REGULATION

Standards for Safeguarding Customer Information (FTC Safeguards Rule, 16 CFR Part 314) - abridged demo excerpt
Effective 2024-05-13 · https://www.ecfr.gov/current/title-16/chapter-I/subchapter-C/part-314

> **§ 314.4** (chunk 1)
> Abridged excerpt of 16 CFR Part 314 prepared for demonstration. Consult the official text in the Code of Federal Regulations before relying on it. § 314.4 Elements In order to develop, implement, and maintain your information security program, you shall: (c) Design and implement safeguards to control the risks you identify through risk assessment, including by: (1) Implementing and periodically reviewing access controls, including technical and, as appropriate, physical controls to authenticate and permit access only to authorized users to protect against the unauthorized acquisition of customer information, and to limit authorized users' access only to customer information that they need to perform their duties and functions; (3) Protect by encryption all customer information held or transmitted by you both in transit over external networks and at rest; (6)(i) Develop, implement, and m...

CODE EVIDENCE

src/lib/db.js:9

```
  ssl: { rejectUnauthorized: true },
```

src/middleware/https.js:3

```
  if (req.secure || req.headers["x-forwarded-proto"] === "https") {
```

src/server.js:14

```
    hsts: { maxAge: 31536000, includeSubDomains: true, preload: true },
```

COMPLIANT

Finding 11

Access to personal data must be restricted to authenticated, authorised users under least privilege.

The cited lines implement the "access-control" control and no conflicting code was found.

REGULATION

Standards for Safeguarding Customer Information (FTC Safeguards Rule, 16 CFR Part 314) - abridged demo excerpt
Effective 2024-05-13 · https://www.ecfr.gov/current/title-16/chapter-I/subchapter-C/part-314

> **§ 314.4** (chunk 1)
> Abridged excerpt of 16 CFR Part 314 prepared for demonstration. Consult the official text in the Code of Federal Regulations before relying on it. § 314.4 Elements In order to develop, implement, and maintain your information security program, you shall: (c) Design and implement safeguards to control the risks you identify through risk assessment, including by: (1) Implementing and periodically reviewing access controls, including technical and, as appropriate, physical controls to authenticate and permit access only to authorized users to protect against the unauthorized acquisition of customer information, and to limit authorized users' access only to customer information that they need to perform their duties and functions; (3) Protect by encryption all customer information held or transmitted by you both in transit over external networks and at rest; (6)(i) Develop, implement, and m...

CODE EVIDENCE

src/middleware/auth.js:12

```
    req.user = jwt.verify(token, config.jwtSecret, { algorithms: ["HS256"] });
```

src/middleware/auth.js:20

```
function requireRole(...allowedRoles) {
```

src/middleware/auth.js:23

```
      return res.status(403).json({ error: "forbidden" });
```

src/routes/admin.js:6

```
// Staff directory. Mounted behind requireAuth + requireRole("admin") in server.js.
```

src/server.js:21-22

```
app.use("/admin", requireAuth, requireRole("admin"), require("./routes/admin"));
app.use("/incidents", requireAuth, requireRole("admin"), require("./routes/incidents"));
```

COMPLIANT

Finding 12

Personal data must be encrypted in transit over external networks.

The cited lines implement the "encryption-in-transit" control and no conflicting code was found.

REGULATION

Regulation (EU) 2016/679 (General Data Protection Regulation) - abridged demo excerpt
Effective 2018-05-25 · https://eur-lex.europa.eu/eli/reg/2016/679/oj

> **Article 32** (chunk 5)
> Article 32 Security of processing 1. Taking into account the state of the art, the costs of implementation and the nature, scope, context and purposes of processing as well as the risk for the rights and freedoms of natural persons, the controller and the processor shall implement appropriate technical and organisational measures to ensure a level of security appropriate to the risk, including inter alia as appropriate: (a) the pseudonymisation and encryption of personal data; (b) the ability to ensure the ongoing confidentiality, integrity, availability and resilience of processing systems and services.

CODE EVIDENCE

src/lib/db.js:9

```
  ssl: { rejectUnauthorized: true },
```

src/middleware/https.js:3

```
  if (req.secure || req.headers["x-forwarded-proto"] === "https") {
```

src/server.js:14

```
    hsts: { maxAge: 31536000, includeSubDomains: true, preload: true },
```

Appendix A: Rules in scope

RULE	SOURCE	EFFECTIVE	IDENTIFIER
Standards for Safeguarding Customer Information (FTC Safeguards Rule, 16 CFR Part 314) - abridged demo excerpt https://www.ecfr.gov/current/title-16/chapter-I/subchapter-C/part-314	federal-register-demo	2024-05-13	DEMO-16CFR314
Regulation (EU) 2016/679 (General Data Protection Regulation) - abridged demo excerpt https://eur-lex.europa.eu/eli/reg/2016/679/oj	eur-lex-demo	2018-05-25	DEMO-CELEX:32016R0679

Appendix B: Methodology and disclaimer

How this report was produced

- Regulatory sources are checked daily. Only rules whose content hash changed since the last check enter an audit.
- Rule text is split into section-aware chunks and embedded into a vector store. The target repository is indexed the same way at the snapshot shown on the cover.
- For each rule, obligations that software must implement are extracted with the chunks that state them.
- For each obligation, code evidence is gathered by keyword search and vector similarity, then assessed as compliant, a violation, or needing review.
- Every citation is then checked without a model: each regulation chunk must exist and belong to the rule, and each `file:line` range must exist in the audited snapshot. Citations that fail are dropped, and a verdict left without both kinds of support is downgraded to "needs review".

Limits

- The audit sees only the indexed repository. Controls implemented in infrastructure, vendor systems or policy documents are invisible to it.
- A "compliant" result means supporting code was found, not that the obligation is fully met.
- Coverage is limited to the rules listed in Appendix A.

Disclaimer

This report is automated decision support. It is not legal advice and it does not guarantee compliance or complete coverage of any regulation. Findings should be reviewed by qualified counsel and engineers before any action is taken on them.